SIMATS ENGINEERING
ASSESSMENT TOOL 1

COURSE NAME: Ethical Hacking **COURSE CODE: ITA14**

COURSE OUTCOME COVERED

CO2: Execute footprinting in social engineering such as DNS analysis, competitive intelligence gathering, and attack simulations to collect relevant information for identifying potential security risks.

Assessment Tool Weightage: 30%

Duration: 90 min **Total Marks: 50**

Report Analysis
Questions

1. A security analyst performed a network scan on the target 192.168.1.10 using the Nmap tool. The report identified several open ports, including HTTP (80), SSH (22), and MySQL (3306), along with the operating system and service versions. Analyze the report and explain the security risks associated with the identified services. Discuss how an attacker could exploit these services and recommend suitable security measures to protect the target system. **(20 Marks)**

2. A phishing awareness campaign was conducted for employees of ABC Technologies Pvt. Ltd. using the GoPhish tool. The report indicates that 40% of employees clicked the phishing link, 20% entered their login credentials, and several users downloaded a malicious attachment. Analyze the report and identify the security weaknesses demonstrated by the employees. Recommend suitable user awareness programs, email security controls, and organizational policies to reduce the risk of successful social engineering attacks.(**20 Mark).**

3. A DNS assessment report generated using the Dig tool shows that the organization's DNS server permits a successful DNS Zone Transfer (AXFR), exposing internal hostnames, mail servers, and DNS records. Analyze the report and explain the security implications of the exposed information. Discuss how attackers could exploit these findings and recommend best practices to secure the DNS infrastructure..**(10 Marks)**

Code of Conduct:

I _____ (Name / Reg No) certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment.
I understand that any violation of academic integrity rules will result in disciplinary action.

Signature of the student:

RUBRICS FOR CALCULATION

Report Analysis

Criteria	Weightage (%)	Level 4 (Exemplary)	Level 3 (Proficient)	Level 2 (Developing)	Level 1 (Beginning)
Report Analysis and Interpretation	25%	Accurately interprets the security report, identifies all key findings, and explains their significance with excellent technical understanding.	Correctly interprets most findings with minor omissions or inaccuracies.	Identifies only some findings and provides limited interpretation.	Unable to interpret the report or identify key findings.
Identification of Security Risks and Vulnerabilities	25%	Correctly identifies all security risks, vulnerabilities, and possible attack vectors with clear technical justification.	Identifies most risks and vulnerabilities with minor errors.	Identifies only a few risks with limited technical explanation.	Fails to identify major risks or vulnerabilities.
Application of Cybersecurity Concepts and Countermeasures	30%	Applies appropriate ethical hacking concepts and recommends comprehensive, practical, and technically sound countermeasures.	Recommends suitable countermeasures with minor technical gaps.	Provides limited or partially appropriate recommendations.	Recommendations are inappropriate, incomplete, or missing.
Technical Communication and Documentation	20%	Response is well-organized, technically accurate, clearly presented, and uses appropriate cybersecurity terminology throughout.	Response is organized and understandable with minor documentation or presentation issues.	Response lacks clarity, organization, or contains several technical inaccuracies.	Response is poorly organized, incomplete, and difficult to understand.

ANSWERS

Name: M Prabhas **Reg No:** 1924722064

Answer 1 (20 Marks)

Report Analysis and Interpretation: The Nmap scan on 192.168.1.10 reveals three open ports: HTTP (80), SSH (22), and MySQL (3306), together with OS and service-version information. Each open port represents a potential entry point, and the version-detection output (service banners) tells an attacker exactly which software and version to target, making this a classic reconnaissance-stage finding that precedes active exploitation.

Security Risks of the Identified Services

- HTTP (Port 80): Unencrypted web traffic can be intercepted or manipulated (man-in-the-middle). If the web application or server software has known CVEs for the detected version, it can be exploited directly. Misconfigured web servers may also leak directory listings, default pages, or admin panels.
- SSH (Port 22): Exposed SSH invites brute-force and credential-stuffing attacks against weak or default passwords. Older SSH versions may carry known vulnerabilities (e.g., weak ciphers, outdated protocol support) that allow downgrade or key-exchange attacks.
- MySQL (Port 3306): A database port reachable from the network is a high-value target. Weak/default database credentials, unpatched MySQL versions, and lack of network segmentation can lead to direct database access, data exfiltration, or SQL injection pivoting.
- OS and Service Fingerprinting: Revealing the OS and exact service versions allows an attacker to map the system to a public exploit database (e.g., Exploit-DB, NVD) and select a precise, pre-tested exploit rather than guessing.

How an Attacker Could Exploit These Services

- Banner grabbing the exact software versions and cross-referencing them with CVE databases to identify a remote-code-execution or privilege-escalation exploit.
- Launching automated brute-force or dictionary attacks (e.g., Hydra) against SSH and MySQL login prompts using common or leaked credential lists.
- Exploiting a vulnerable web application on port 80 (SQL injection, file upload, outdated CMS plugin) to gain a foothold, then pivoting laterally to the MySQL service using discovered database credentials.
- Chaining the three findings together: using the web server as an entry point, escalating through SSH, and finally exfiltrating data from MySQL - a typical attack-path progression.

Recommended Security Measures

- Close or firewall any port not strictly required for business operations; restrict MySQL (3306) to internal/management networks only, never expose it to the internet.
- Patch and update the OS, web server, SSH daemon, and MySQL to the latest stable versions to remove known vulnerabilities.
- Enforce HTTPS/TLS for the web service and disable weak ciphers; implement a Web Application Firewall (WAF).
- Harden SSH: disable password authentication in favour of key-based authentication, change the default port, enable fail2ban/rate-limiting, and disable root login.
- Use strong, unique credentials and least-privilege database accounts for MySQL; enable logging and intrusion-detection/prevention systems (IDS/IPS).

- Perform regular vulnerability scanning and penetration testing to catch newly exposed services or misconfigurations before attackers do.

Answer 2 (20 Marks)

Report Analysis and Interpretation: The GoPhish campaign results for ABC Technologies Pvt. Ltd. show 40% of employees clicked the phishing link, 20% submitted login credentials, and several downloaded a malicious attachment. These figures indicate the human layer is currently the weakest link in the organization's security posture, since a sizeable proportion of staff could not distinguish a simulated phishing email from a legitimate one.

Security Weaknesses Demonstrated by Employees

- Low phishing awareness: 40% clicking the link shows employees do not routinely verify sender addresses, hover over links, or question unexpected requests.
- Poor credential hygiene: 20% entering credentials on a fake page indicates employees cannot identify spoofed login pages and may be reusing passwords across systems, increasing the blast radius of a real compromise.
- Unsafe attachment handling: Users downloading and likely opening an unsolicited attachment shows a lack of basic email-hygiene practices, which could lead to malware or ransomware execution on endpoint machines.
- Absence of a reporting culture: The report implies employees did not flag the suspicious email to IT/security teams before interacting with it, delaying detection and response.

Recommended User Awareness Programs

- Conduct periodic, mandatory security-awareness training with real-world phishing examples, scored quizzes, and refreshers at least twice a year.
- Run continuous simulated phishing campaigns (like this GoPhish exercise) with immediate, constructive feedback for employees who click, so lessons are reinforced in the moment.
- Introduce a visible 'Report Phishing' button in the email client and reward/recognize employees who correctly report suspicious emails.

Email Security Controls

- Deploy SPF, DKIM, and DMARC to reduce email spoofing and domain impersonation.
- Use a secure email gateway with attachment sandboxing, link-rewriting/time-of-click URL scanning, and spam/phishing filters.
- Enable multi-factor authentication (MFA) on all accounts so that stolen credentials alone are not sufficient for account takeover.
- Apply endpoint protection (EDR/antivirus) and application whitelisting to limit damage from malicious attachments that do get opened.

Organizational Policies

- Adopt a clear acceptable-use and password policy (unique, strong passwords; no credential reuse; mandatory periodic password changes).
- Enforce the principle of least privilege so a single compromised account cannot access sensitive systems broadly.
- Establish an incident-response plan with defined escalation paths so suspected phishing incidents are contained quickly.
- Track and report phishing-simulation metrics to leadership to drive continuous improvement in the organization's security culture.

Answer 3 (10 Marks)

Report Analysis and Interpretation: The Dig-based DNS assessment shows that the organization's authoritative DNS server allows an unrestricted zone transfer (AXFR) to any requester. This misconfiguration exposes the complete DNS zone file, including internal hostnames, mail server (MX) records, subdomains, and other DNS records that should normally remain confidential.

Security Implications of the Exposed Information

- A successful AXFR hands an attacker a ready-made map of the internal network: server names, mail infrastructure, and possibly internal IP ranges, without any active scanning.
- Exposed subdomains (e.g., dev, staging, vpn, admin) reveal high-value targets that are often less protected than production systems.
- Knowledge of mail server records assists in crafting convincing spoofed or spear-phishing emails.
- Overall, the zone transfer drastically reduces the reconnaissance effort required for a targeted attack, shortening the time from footprinting to exploitation.

How Attackers Could Exploit These Findings

- Use the disclosed hostnames and subdomains to prioritize targets for vulnerability scanning and exploitation.
- Map the internal network topology and identify forgotten or legacy systems with weaker security controls.
- Leverage mail server details for email spoofing, phishing, or man-in-the-middle attacks on mail traffic.

Best Practices to Secure the DNS Infrastructure

- Restrict zone transfers (AXFR) to explicitly authorized secondary DNS servers only, using access-control lists (ACLs) or TSIG authentication.
- Disable zone transfer requests from arbitrary/public IP addresses entirely on authoritative name servers.
- Split DNS views (internal vs. external) so only necessary public records are resolvable from the internet.
- Regularly audit DNS configurations using tools such as dig, dnsrecon, or Nmap NSE scripts to verify that zone transfers and other misconfigurations are not re-introduced.
- Keep DNS server software patched and monitor DNS query logs for unusual AXFR or reconnaissance activity.